

Information Security Policy

Policy ID: HH-ISMS-01 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

1. Purpose

Information security is not optional at a hospital. Haritha Hospitals stores personally identifiable health information (PHI), employee compensation data, and operational records that — if leaked, corrupted, or destroyed — cause direct harm to patients, staff, and the business.

Three failure modes we defend against:

- **Confidentiality loss.** Patient names + diagnoses or employee salaries landing on a USB stick or a public pastebin. Legal liability under IT Act 2000 + DPDP Act 2023. Reputational damage that survives the news cycle.
- **Integrity loss.** A clinician acting on a tampered medication record, or HR paying the wrong salary because attendance was silently corrupted. Both are clinical/financial incidents, not “data issues”.
- **Availability loss.** Roster unavailable on shift-change morning, payroll unable to compute salaries on the 1st. Recovery from ransomware takes days, not minutes, without verified backups.

This policy is the umbrella under which all other ISMS documents exist. It states the rules; the other policies (access control, asset management, cryptography, operations security, etc.) state how we implement them.

2. Scope

Applies to **everything** that touches Haritha Hospitals information:

- **Systems.** Production (pberpprod, sites pberpPROD.duckdns.org), Dev (pberpdev), QA (pberppqa), plus the haritha_hospital custom app, all bench containers (erp-{env}-{backend,frontend,db,redis,scheduler}), the VPS host (vps-3248b821, 144.217.163.228), and Venkat's offsite backup VPS (135.125.196.35).
- **Data.** Patient records, employee records (HR, payroll, attendance), financial data, configuration, code, runbooks, credentials, audit logs.
- **People.** Venkat (owner/admin), any contracted developer, any intern with temporary access, and Processbricks staff acting on Haritha's behalf.
- **Vendors.** Anyone with read/write access to Haritha systems or data — currently limited to the duckdns dynamic-DNS provider and Let's Encrypt (see 04-cryptography for cert handling).
- **Environments.** Both container-attached (frappeclaw-data workspace) and the VPS-side /home/vijay/frappeclaw/ compose trees.

3. Policy Statement

The following rules are non-negotiable:

1. **Patient data is confidential.** Never share, screenshot, dump, or export patient records without documented authorization. “Authorization” means a written ticket naming the records, the recipient, the purpose, and the expiry.
2. **All access must be authenticated and authorized.** Anonymous access to any data-bearing endpoint is a security incident, not a feature. See 02-access-control for how.

3. **Security incidents must be reported within 1 hour of discovery.** Use the SEV classification in 04.4 Incident Response Plan. Do not investigate first, do not fix first — **report first**. Slack DM Venkat, then triage.
4. **Backups are mandatory (3-2-1).** At least 3 copies of production data, on 2 different media, with 1 copy offsite. The offsite target is venkat@135.125.196.35 (rsync, daily 03:30 IST cron). The third copy is the local backup volume. Verify weekly — see 04.3 Disaster Recovery and 05-operations-security.
5. **No production data on personal devices.** No laptop, no USB stick, no personal phone. Production data lives in the production container or in the production backup pipeline. Period.
6. **Annual security training is required.** Every person with access reads this policy set + the runbooks annually and signs off in the access register. New joiners complete this within their first 30 days.
7. **No secrets in git.** No DB passwords, SSH private keys, API tokens, or .env files. Even for dev. Even “temporarily”. Pre-commit hook + manual review on every PR. See 04-cryptography.
8. **Least privilege by default.** New users start with the minimum role that lets them do their job. Privilege escalation is explicit, time-boxed, and audited. See 02-access-control.
9. **Documented exceptions only.** Deviations from this policy require a written exception (see §6). “I was busy” or “we’ll fix it later” is not an exception — it’s an undocumented violation.

3a. Current State (as of 2026-08-29)

What Haritha has in place today, what is working, and what is a known gap.

What we have TODAY

Layer	Component	Where it lives	Status
Identity	tabUser per environment	MariaDB on erp-prod-db-1, erp-dev-db-1, erp-qa-db-1	Live
Identity	RBAC roles + Custom Roles	apps/haritha_hospital + fixtures	Live
Identity	MFA (TOTP) for System Manager / Administrator	Frappe framework	Live (enforced for Venkat only)
Perimeter	TLS via Let’s Encrypt	Nginx in erp-prod-frontend-1 (* .duckdns.org)	Live, auto-renewed
Perimeter	SSH key-only auth (no password)	VPS vps-3248b821 + offsite 135.125.196.35	Live
Perimeter	PermitRootLogin no	/etc/ssh/sshd_config on both VPSes	Live
Data	3-2-1 backups	Local /home/vijay/backups + offsite venkat@135.125.196.35: /home/venkat/pberp*_backups/	Live, cron proven (LEARNINGS #79)
Data	Offsite rsync daily 03:30 IST	cron on VPS as vijay	Live, verified heartbeat

Layer	Component	Where it lives	Status
Monitoring	Daily ops runbook	../04-runbooks/04.2-daily-ops.md	Live, executed by admin
Response	Incident response plan + SEV ladder	../04-runbooks/04.4-incident-response.md	Live, table-topped
Recovery	Disaster recovery procedure	../04-runbooks/04.3-disaster-recovery.md	Live, restore test on 2026-08-19 (slot #1 + #2 PASSED)
Compliance	This policy set	docs/phase6/09-compliance/	v1.0, just authored
Secret mgmt	Container env vars (DB passwords)	MYSQL_ROOT_PASSWORD on erp-{env}-db-1	Live, but historically prone to drift — see LEARNINGS #154

What is WORKING

- **Backups are now reliable.** prod_backup.sh was retrofitted on 2026-08-18 with time-out 900, set -euo pipefail, and hrms ghost-installed_apps purge (LEARNINGS #79 + #80). 2026-08-19 verification showed slot #1 (00:00 IST) and slot #2 (06:00 IST) both PASSED — eight-day silent-failure streak reset.
- **TLS is auto-renewing.** Let's Encrypt certs on *.duckdns.org renew via certbot timer; daily heartbeat probes cert expiry (target: > 14 days remaining). No cert incident since the rotation began.
- **Single-tenant container network.** Backend ↔ DB on 172.27.0.0/16 Docker bridge — no encryption, but no other tenants either.
- **RBAC roles ship via fixtures.** Custom Roles + Role Profile customizations are exported from haritha_hospital and apply idempotently across envs (LEARNINGS #151, #152, #157).

Known GAPS (be honest)

1. **No encrypted backups at rest.** Local + offsite tarballs are plaintext. Acceptable for v1 (single-operator trust model); addressed as future in 04-cryptography §3.6.
2. **No column-level encryption.** tabSalary Slip.net_pay, tabPatient Medical Record.diagnosis, etc. are plaintext in the DB. Mitigated by access control + audit logs, not by crypto.
3. **No automated DLP / secret scanning in CI.** Pre-commit hook exists but only runs on the developer's machine; a CI-side git-secrets job is a future improvement.
4. **No annual penetration test.** Single engineer; “internal audit” is Venkat walking the OWASP Top 10 against the stack. Documented limitation.
5. **No formal asset-inventory doc.** Inventory is in Venkat's head and partially in this policy doc (see 03-asset-management §6 Exceptions). Will be authored as asset-inventory.md next batch.
6. **MFA coverage incomplete.** Only System Manager / Administrator users are MFA-enrolled by policy. Employee-role users (front desk, nurses) are password-only. Future: enforce MFA tenant-wide once Frappe framework supports a single toggle.
7. **No security awareness training program.** Annual sign-off is mandated by policy §3.6 but no curriculum exists yet.

These gaps are not surprises — they are explicit v1 scope decisions. The point of naming them here is so a future reader (or auditor) doesn't assume the policy claims something it does not.

3b. Concrete Examples (Haritha history)

Real incidents and near-misses that shaped this policy. Each is a worked example of how the rules above would have prevented (or did prevent) real damage.

Example 1 — 2026-08-18 prod backup silent-failure streak (LEARNINGS #79, #80)

- **What happened.** `prod_backup.sh` ran 4x/day from 2026-08-10 through 2026-08-18. Every slot failed silently. The cron wrote no error, the offsite rsync target was empty, and the on-call admin had no idea.
- **Root cause.** Two stacked bugs: (a) `bench backup --with-files` has no built-in timeout and a stale `sites/apps.txt` `hrms` reference caused a 1-second `ModuleNotFoundError` exit (LEARNINGS #80); (b) the wrapper script's `set -euo pipefail + $(ls *.tar.gz)` command-substitution trap (LEARNINGS #113) swallowed any residual error. Neither alone would have been silent — both together were.
- **Response.** 2026-08-18: Venkat discovered the gap during a manual restore drill. Patched `prod_backup.sh` with `timeout 900 docker exec ... bench ... backup --with-files`, removed the ghost `hrms` from `apps.txt` + `site_config.json`, added `PIPESTATUS[0]` exit capture, added `stderr tee` to `/tmp/backup-*.log`. Verified 2026-08-19 with two consecutive cron slots passing.
- **Policy lesson.** “Backups are running” is not the same as “backups are succeeding”. Backup verification must be a positive probe (count rows in restored DB), not just a cron succeeded check. This is exactly what §5 “Monthly backup verification” enforces — a sanity query against a scratch MariaDB.

Example 2 — 2026-08-29 prod DB password drift / 401 incident (LEARNINGS #154, #157)

- **What happened.** Production DB login returned 401. Venkat reached for the password in `MEMORY.md` — both stored literals (`9b35e477b5ede662` and `eGtsatXqERFAvW4M`) were stale. The actual prod `MYSQL_ROOT_PASSWORD` had been rotated in a previous ops session but never updated in `MEMORY.md`.
- **Root cause.** Hardcoded credentials in a doc-of-record that was never re-verified. The “source of truth” was the container env, not the doc. The doc claimed authority it did not have.
- **Response.** Verifying pattern (per LEARNINGS #154) became canonical: `docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD` is the only authoritative read. `MEMORY.md` retains CAUTION notes that literals may be stale; quarterly verification is now policy (§5 of 04-cryptography).
- **Policy lesson.** Secrets are not constants — they are living state. The corollary is that documentation about secrets must be either (a) generated FROM the source of truth, or (b) explicitly marked stale + scheduled for verification. Hardcoded literals in long-lived markdown are an anti-pattern.

Example 3 — 2026-08-29 unicorn --preload outage (LEARNINGS #153)

- **What happened.** After `bench install-app haritha_hospital` on running backend containers (both `pberpprod` and `pberpdev`), every HTTP request returned `ModuleNotFoundError: No module named 'haritha_hospital'` → HTTP 500. Both prod and dev were down for ~30-60s each.

- **Root cause.** Gunicorn PID 1 with `--preload` freezes `sys.path` at startup; new packages installed afterwards are invisible until container restart. `bench restart` does NOT restart gunicorn (it only reloads the bench process), so the recovery required `docker restart erp-{env}-backend-1`.
- **Response.** Both backends restarted in parallel. Zero data loss. Post-incident: added a mandatory `docker restart` step to the post-install runbook (`../04-runbooks/04.1-deployment.md`).
- **Policy lesson.** “Deploy succeeded” $\neq$ “Service healthy”. Post-deploy verification must probe the running process, not just the install exit code. This is why §1 mentions the integrity failure mode (a tampered/clinically-relevant record could be served from a broken backend just as easily as from a malicious one).

Example 4 — 2026-08-10..18 scheduler drift risk (LEARNINGS #88, #89)

- **What happened.** `apps.txt` was modified 2026-08-20 17:53 IST to add `hrms+payments`, but a scheduler restart at 02:48 UTC triggered `ModuleNotFoundError`. `pberp-scheduler-1` crash-looped with 5 restarts in 21 minutes. `erp-{prod,qa,dev}-scheduler` had the same drift but `RestartCount=0` since 2026-08-19 — any restart would have crashed identically.
- **Root cause.** `apps.txt` $\leftrightarrow$ `apps/` folder drift; the scheduler crashed silently. The heartbeat caught it (LEARNINGS #90 — heartbeat must run actual probes) but only because Venkat was watching.
- **Response.** `Apps.txt / site_config.json` reconciliation added to pre-deploy checklist. Heartbeat now asserts scheduler container `RestartCount == 0` as part of the daily ops probe.
- **Policy lesson.** “No silent failures” is not a slogan — it is a measurable property (`RestartCount`, exit codes, log lines per slot). This is why §5 of this policy lists specific probes, not just “monitor the system”.

Example 5 — 2026-08-18 cron race condition (LEARNINGS #78)

- **What happened.** Three agents concurrently editing the crontab with `crontab -l | sed ... | crontab -`. Each agent’s `crontab -l` returned whatever the previous agent most recently wrote. Last-writer-wins, no diff, no warning. Final state diverged from all three agents’ intents.
- **Root cause.** The crontab is shared system state; the `crontab -l | sed | crontab -` pattern has no transactional isolation.
- **Response.** New canonical pattern: `crontab <heredoc-tempfile>` from a backup-aware heredoc, with `hash-before / hash-after` verification. Post-recovery crontab hash: `941eeefc977ae1aabb185e8a5a94c4dcdeed649d45ca67b72f0ba60e4a98127`.
- **Policy lesson.** State mutations (cron, secrets, config files) need the same care as DB writes: backup, verify, lock, audit. This dovetails with §3 rule 10 (documented exceptions) — silently editing shared system state in a hurry is exactly the kind of “we’ll fix it later” violation the rule forbids.

Example 6 — 2026-08-11 chart config + roster delete-after-submit (LEARNINGS phase6/04 Wave 5)

- **What happened.** During `pberpDEV HRMS Recruitment/Performance/Training wave-5` retry, a Roster doc was `delete-after-submit` by default. A test entry created during chart-config exploration was silently dropped the moment it was submitted. The wave-5 verification step had no record of the entry existing post-submit, so the test looked like a flake.

- **Root cause.** Frappe framework default for some HRMS docs is `delete_after_submit = 1`. Custom apps inherit the default unless explicitly overridden in the DocType JSON. No warning is emitted; no audit row is kept.
- **Response.** Wave-5 script updated to query `tabVersion` (audit log) to detect soft-deletes. Chart-config test fixtures now use named, persisted sample data that survives the submit cycle.
- **Policy lesson.** “Audit logs” are not optional — they are the difference between an investigation that takes an hour and one that takes a week. `tabVersion` is the authoritative answer to “what did this doc look like yesterday?”. This is why §5 lists audit-log review as a recurring check.

Example 7 — 2026-08-14 sub-agent verification gap (LEARNINGS 2026-08-14 batch)

- **What happened.** A subagent reported “ready” after editing `ssh heredoc` for the offsite rsync script. The script was syntactically valid but the heredoc-escape inside a docker exec shell had unescaped backticks, causing the cron to expand a command (the `$(date)` inside the rsync log path) before the heredoc was even written to file. Result: the offsite log filename was the literal output of `date` at heredoc-write time, not at rsync runtime. Logs were indistinguishable from each other across days.
- **Root cause.** Subagent verified “the script parses” but not “the script behaves”. A behavior assertion (the file written contains a literal `$(date)`, not its expansion) was missing.
- **Response.** Added behavior assertions to the subagent’s checklist. Heredoc now uses single-quoted delimiter (`'EOF'`) which disables shell expansion inside the heredoc body — so `$(date)` survives to rsync time.
- **Policy lesson.** “Verified” is a claim about behavior, not syntax. This is why §5 KPIs are written as positive probes (e.g., “offsite backup freshness $\leq$ 26h lag”) rather than as “backup ran without error”. The 2026-08-10..18 backup streak failed the “ran without error” check by hiding the error entirely; the 2026-08-14 subagent example is the same class of failure at smaller scale.

Example 8 — 2026-05-28 VPS timezone + cron restart interaction (LEARNINGS)

- **What happened.** VPS timezone was changed (e.g., container time drifted after a host reboot). Cron daemon, however, was still using the OLD timezone for its schedule evaluation. Jobs that “should have run” did not run for ~6 hours until cron was restarted and re-read the new timezone.
- **Root cause.** cron reads `/etc/localtime` and `/etc/timezone` only at start. Timezone changes do not auto-propagate to running cron daemons.
- **Response.** Standard post-timezone-change checklist now includes `systemctl restart cron` (or `docker restart` if cron runs in a container). Daily ops heartbeat verifies the slot ran within ± 15 min of expected time.
- **Policy lesson.** “Configuration” is runtime state, not just files on disk. Any config that requires a process to re-read it must trigger a controlled restart, and the restart must be auditable. This is why §5 Compliance Measurement tracks offsite backup freshness $\leq$ 26h lag — the lag is a positive probe that catches drift in cron timing, container restarts, network blips, and other things that a “backup ran” check would miss.

Example 9 — 2026-05-23 SSH key compromise + backup key handling (LEARNINGS)

- **What happened.** A test scenario: Venkat’s laptop was compromised. The primary SSH key (`/root/.openclaw/ssh_key`) for the VPS was on it. The offsite backup VPS (135.125.196.35) had a SECOND key (`/root/.openclaw/venkat_vps_key`) on a different machine, not the laptop.

- **Root cause (hypothetical).** Single-key infrastructure means a laptop compromise equals a total compromise.
- **Response.** Verified the key-separation model: primary key on Venkat's machine (admin surface), separate key on a different machine for offsite rsync (data surface). Compromise of one does not equal compromise of the other. Documented in the secret register.
- **Policy lesson.** Defense in depth — and specifically, blast-radius separation — is a property of key distribution, not just algorithm strength. A 4096-bit RSA key is still 100% compromised if it's the only key on the only machine the attacker has. This is why §3 rule 4 (SSH key rotation, separate per host) is enforced even though it feels redundant for a single-operator model.

4. Responsibilities

Role	Responsibilities
Venkat Narasimha (Owner)	Approves this policy + exceptions. Owns the risk register. Annual review. Final escalation point for SEV-1/SEV-2.
Processbricks admin	Implements access control, backup verification, secret rotation. Monitors logs daily. Reports anomalies within 1 hour.
All users	Read + acknowledge this policy annually. Comply with access control (don't share creds, don't bypass MFA). Report incidents within 1 hour. Protect credentials (no shoulder-surfing, no plain-text storage).
Vendors	Bound by contract to these rules. Read-only where possible. Any sub-processor they use gets the same treatment.
Subagents / automation	Read policy set before acting on prod data. Never run bench console against prod without an approved ticket. Never write to <code>tabSingles</code> or <code>tabDocType</code> directly — use <code>fixtures + frappe.get_doc().save()</code> (LEARNINGS #157).

5. Compliance Measurement

We verify this policy on a recurring cadence:

- **Quarterly access review.** Pull `tabUser` + role assignments, reconcile against the access register. Any user without a current business need loses access within 24h. Owner: Venkat.
- **Monthly backup verification.** Restore the latest tarball to a scratch MariaDB, run a sanity query (`SELECT COUNT(*) FROM \tabPatient' etc.'`), compare against prod counts. Owner: admin. Reference: 04.3 Disaster Recovery restore checklist.
- **Annual penetration test.** Out of scope for v1 (no budget); planned once a second engineer joins. Until then, "internal audit" = Venkat + structured walk-through of the OWASP Top 10 against the running stack.
- **Weekly log review.** Tail `frappe-bench/logs/*.log`, `nginx` access log, and `SSH` auth log. Look for `auth failures`, `unauthorized`, `permission denied`, `4xx/5xx` spikes. Owner: admin.

- **Quarterly secret audit.** Verify no plaintext secrets in repo (`git grep -iE 'password|secret|token' -- ':!*/docs/**' | grep -v '\.md:'`). Verify `.env` files outside containers are gitignored. Owner: Venkat.
- **Annual policy review.** Re-read every policy in `09-compliance/`, update version + Last Reviewed fields, archive the diff. Triggered by Venkat.

KPI dashboard (informal, not a Grafana board):

KPI	Target	Source
Offsite backup freshness	≤ 26h lag	rsync target timestamp
Failed login rate	≤ 5/day average	frappe-bench logs
Unresolved SEV-1/2 incidents	0	Slack #ops channel
Users without MFA on prod	0	tabUser + 2FA table

6. Exceptions

Exceptions are **rare, documented, and time-boxed**. Process:

1. Requester opens an “Exception Request” doc (free-form: asana task or a Markdown file in `09-compliance/exceptions/`) naming the policy clause, the reason, the compensating control, and the expiry date.
2. Venkat reviews within 24h. Reject, approve, or modify.
3. Approved exceptions are logged in the access register / exception log with start + end dates.
4. On expiry: control reverts automatically. If extension is needed, a new request is filed (no silent renewals).
5. Emergency exceptions (e.g., “production is down and we need to share a DB password over Slack to recover”) are pre-approved verbally, but the written exception must be filed within 24h of the incident close. Post-incident review covers what could have prevented the emergency.

6a. Edge Cases & Decision Matrix

Beyond the standard exception flow above, the following edge cases have been encountered (or anticipated) at Haritha. Each entry includes the trigger, the recommended action, and the rule that resolves it.

Edge case 1 — Subagent / automation must touch prod data

- **Trigger.** A scheduled agent or a one-off subagent task needs to read (or write) prod records (e.g., bulk-updating salary components during a comp revision).
- **Decision matrix.**

Capability	Allowed?	Conditions
Read public/Internal data	Yes	With audit log entry naming the agent + task ID
Read Confidential data (PHI, payroll)	Conditional	Only via <code>frappe.get_list</code> / <code>frappe.get_doc</code> with the calling user’s System Manager role already granted per §2-access-control. No bypass.

Capability	Allowed?	Conditions
Write any prod row	Conditional	Same as Confidential read, + pre/post row count + diff captured in the task log
Run bench console against prod	Rarely	Approved ticket only; prefer fixtures or scheduled task. Never for ad-hoc exploration.
Write to tabSingles or tabDocType directly	NO	Use fixtures + <code>frappe.get_doc().save()</code> (LEARNINGS #157). Direct writes silently break framework invariants.

- **Default action.** Refuse and route through a Venkat-approved ticket. The cost of refusal is low (a few hours delay); the cost of unauthorized prod write is catastrophic (silent corruption, audit-trail gap).

Edge case 2 — Shared workstation at the front desk

- **Trigger.** Reception desk has one Windows machine used by 6 nurses across 3 shifts. Each nurse needs her own tabUser, but the workstation is shared.
- **Decision matrix.**

Behavior	Allowed?	Why
One tabUser per nurse, shared workstation	Yes	Identity is the nurse's, not the workstation's. Each nurse logs in with her own credentials.
One "reception account" shared across nurses	NO	Violates §3.1.3 (no shared accounts); audit trail is destroyed.
Auto-login as reception@shift-A	NO	Same reason + idle-session risk.
Idle-session timeout = 15 min	Required	Compensating control for shared workstation. Frappe framework setting.

- **Default action.** Provision per-nurse tabUser with Employee role. Configure Frappe's session expiry to 15 min idle / 8h absolute. Document in the access register.

Edge case 3 — Vendor (e.g., Let's Encrypt, duckdns) requires a webhook or token

- **Trigger.** duckdns needs the VPS's public IP to update *.duckdns.org. Certbot needs an ACME challenge endpoint. Both technically require a "shared secret" of some kind.
- **Decision matrix.**

Vendor	What we share	How	Rotation
duckdns	Update token (long opaque string)	Container env var on <code>frappeclaw compose</code>	Annual; revoke on personnel change of anyone with access

Vendor	What we share	How	Rotation
Let's Encrypt	ACME HTTP-01 challenge (public)	Public endpoint, no secret	n/a (challenge is per-cert)
Processbricks contractors (if any)	Scoped Frappe API token	Container env var + IP allowlist	Per-engagement

- **Default action.** Container env vars only, scoped tokens, rotation per policy §4-cryptography §3.5.

Edge case 4 — Backup restoration during an incident (DR drill or real recovery)

- **Trigger.** Production is suspected corrupt; we need to restore from offsite backup.
- **Decision matrix.**

Step	Allowed?	Owner
Restore latest tarball to a scratch MariaDB on dev VPS	Yes	admin
Run sanity queries (SELECT COUNT(*) against key tables)	Yes	admin
Diff against prod counts (acceptable drift window: ±5%)	Yes	admin
Promote the restored DB to be prod	ONLY with Venkat's approval	Venkat
Skip the dry-run + diff	NO	—

- **Default action.** Always dry-run on dev/QA first. Document the diff. Promotion is a deliberate act, not a side-effect of “we restored and it worked”.

Edge case 5 — Offsite VPS (venkat@135.125.196.35) becomes unreachable

- **Trigger.** Offsite VPS down for > 24h. We lose the offsite 1-of-3 in the 3-2-1 rule.
- **Decision matrix.**

Hours down	Action
0-4h	Monitor; verify it's not our local network.
4-24h	Alert Venkat (SEV-3). Defer non-critical offsite rsyncs. Continue local backups.
24-72h	SEV-2. Document the gap in 09-compliance/exceptions/. Consider adding a second offsite (e.g., B2 / Wasabi).
> 72h	SEV-2. Policy temporarily violated; restore cadence resumes once offsite is back. Annual review asks “do we need a second offsite?”.

- **Default action.** SEV-2 after 24h. Never silently let backups accumulate only locally — the 3-2-1 invariant must be restored or formally waived.

Edge case 6 — Personnel change (Venkat is unavailable for > 7 days)

- **Trigger.** Owner is unreachable. No one else can approve exception requests or grant role elevations.
- **Decision matrix.**

Scenario	Action
Routine user provisioning	Defer until Venkat returns; existing users continue working
Production DB down	Emergency-access flow per §2-access-control §6 — elevate on-call admin, log action, notify Venkat on contact
Security incident (SEV-1/2)	Same emergency-access flow; document in /var/log/erp-emergency-access.log
Quarterly access review	Skip the cycle, document the skip in the access register, perform double-cycle on return

- **Default action.** Document the unavailability in the access register. Do not invent a new approval authority — that’s the kind of “we’ll fix it later” violation §3 rule 10 forbids.

Edge case 7 — A tabUser is suspected compromised

- **Trigger.** Failed-login spike, foreign IP in auth log, or a credible external report.
- **Decision matrix.**

Signal	First action
Failed-login rate > 5/day from one IP	Auto-lockout (Frappe framework) + alert
Successful login from a never-seen ASN	Disable account within 1h, force password reset on next touch
API token used from an IP outside the allowlist	Revoke token immediately, audit last 24h usage
User reports they were phished	Disable account, rotate all secrets the user could touch, audit

- **Default action.** Disable first, investigate second. Restoration is reversible; data exfiltration is not.

7. Related Documents

- 02-access-control.md — Who can access what, how, and for how long.
- 03-asset-management.md — Inventory and data classification.
- 04-cryptography.md — How we protect data in motion and at rest.
- 05-operations-security.md — Backups, patching, monitoring, change control.
- 07-incident-management.md — SEV classification + escalation.
- 08-business-continuity.md — DR + RTO/RPO targets.
- ../04-runbooks/04.3-disaster-recovery.md — Restore procedure.
- ../04-runbooks/04.4-incident-response.md — Triage flow.
- ../../../../learnings/LEARNINGS.md — Lessons #114 (silent cron failures), #153 (unicorn restart), #154 (DB password drift).

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial
1.1	2026-08-29	venkat-narasimha	Added §3a Current State, §3b Concrete Examples (5 worked incidents), §6a Edge Cases & Decision Matrix (7 scenarios). Cross-linked LEARNINGS #78, #79, #80, #88, #89, #90, #113, #153, #154, #157.

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ☐ **Draft docs/phase6/09-compliance/asset-inventory.md** with rows for VPS hosts, off-site VPS, all containers, all envs, all DBs. Owner: VN. Target: 2026-09-05. Status: Not Started.
- ☐ **Add git-secrets (or equivalent) CI job** that scans every PR for known patterns (password=, token=, BEGIN.*PRIVATE KEY, Aadhaar 12-digit). Owner: VN. Target: 2026-09-12. Status: Not Started.
- ☐ **Wire pre-commit hook install** into scripts/bootstrap.sh so every fresh clone has the secret-scanning hook by default. Owner: PA. Target: 2026-09-05. Status: Not Started.

Short-term (this quarter, 2026-Q3)

- ☐ **Enforce idle-session timeout = 15 min / absolute = 8h** on pberpprod (then dev/qa). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Provision per-user tabUser for all front-desk nurses** (currently may share via shift-account shortcut). Owner: VN. Target: 2026-10-15. Status: Not Started.
- ☐ **Author security awareness training deck** for annual sign-off (§3.6). 30 slides max, concrete Haritha examples, quiz at end. Owner: VN. Target: 2026-10-31. Status: Not Started.
- ☐ **Document offsite-VPS-down runbook** (cross-link to Edge Case 5 above). Owner: VN. Target: 2026-09-30. Status: Not Started.

Medium-term (2026-Q4)

- ☐ **Implement encrypted backup at rest** with age symmetric encryption (key in sealed envelope + offsite paper). Closes §3.6 future item. Owner: VN. Target: 2026-12-15. Status: Not Started.
- ☐ **Add MariaDB transparent data encryption** (innodb_encrypt_tables=ON) — needs key management decision (HashiCorp Vault? Passphrase file? Sealed key?). Owner: VN. Target: 2026-11-30. Status: Not Started.

- ❑ **MFA-enroll all Employee-role users** (currently password-only). Owner: PA. Target: 2026-11-15. Status: Not Started.
- ❑ **Quarterly backup verification ritual formalized** — script + calendar reminder + result-logged doc. Owner: PA. Target: 2026-10-31. Status: Not Started.

Long-term (2027+)

- ❑ **Annual penetration test** engagement — deferred until a second engineer joins. Owner: VN. Target: TBD. Status: Blocked.
- ❑ **Column-level encryption** for tabSalary Slip.net_pay + patient diagnosis fields. Cost: high (schema migration, search index tradeoffs). Owner: VN. Target: TBD. Status: Not Started.
- ❑ **DLP scanning of all PR diffs** for likely-Confidential patterns (Aadhaar-like numbers, debit card patterns, phone-number shapes). Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (no completion date — runs forever)

- ❑ **Daily log review** (4xx/5xx spike, auth failures, permission denied). Owner: PA. Frequency: daily. Status: Done (in 04.2-daily-ops.md).
- ❑ **Weekly log archive** (rotate + gzip + ship to offsite). Owner: PA. Frequency: weekly. Status: Done.
- ❑ **Monthly backup verification** (restore + sanity query + count diff). Owner: PA. Frequency: monthly. Status: Done.
- ❑ **Quarterly access review** (reconcile tabUser ↔ access register). Owner: VN. Frequency: quarterly. Status: In Progress.
- ❑ **Quarterly secret audit** (git grep + .gitignore integrity check + container env vs access register). Owner: VN. Frequency: quarterly. Status: In Progress.
- ❑ **Quarterly DB password re-verification** (per LEARNINGS #154 pattern). Owner: PA. Frequency: quarterly. Status: Done.
- ❑ **Annual policy review** (re-read every doc in 09-compliance/, increment version). Owner: VN. Frequency: annually. Status: Done (this revision).